

SOC ANALYST LEVEL 1

Lecture 9: Introduction to SIEM

How a SOC Analyst uses SIEM to understand alerts and correlate events

Author: [Nader Anam](#) | Duration: 3
Hours

LECTURE OBJECTIVES

- ✓ Deeply understand the core meaning of SIEM.
- ✓ Master the concept of Log Sources & data feeds.
- ✓ Comprehend Parsing and Normalization mechanics.
- ✓ Distinguish between Events, Alerts, and Incidents.
- ✓ Grasp the purpose and utility of Correlation Rules.
- ✓ Learn how to navigate and interpret Dashboards.
- ✓ Learn how to launch an investigation within SIEM.
- ✓ Know the essential schema fields for analysis.
- ✓ Implement user, host, IP, and hash pivot tactics.
- ✓ Build a baseline chronological investigation timeline.

WHY IS THIS LECTURE IMPORTANT?

Up until this point in the course, you have learned about critical components in isolation:

Telemetry Components

Network, Windows, and Linux operating system logs.

Attack Vectors

Phishing mechanics, delivery patterns, and email headers.

Frameworks

MITRE ATT&CK framework mapping and Alert Triage steps.

Now, we need to bring all of these distinct parts into **one centralized interface**. That interface is the **SIEM**—the brain of the SOC operations team.

| WHAT IS SIEM?

SIEM stands for **Security Information and Event Management**.

It is an enterprise security system that aggregates massive streams of log data from across the infrastructure to support:

-  Log Collection & Storage
-  Fast Querying and Searching
-  Event Correlation Logic
-  Real-time Security Alerting
-  Visual Dashboards
-  Incident Management Support

WHY DO WE NEED SIEM?

Without a SIEM, security logs are scattered across dozens of individual silos:

Endpoints

Windows Event Viewer & Linux syslog records.

Perimeter

Firewall traffic, Proxy histories, and VPN login entry logs.

Applications

Cloud architecture logs and Email Gateway security feeds.

The Core Problem: Each source only tells a fraction of the story. SIEM integrates them to give you the complete picture.

AN ATTACK SCENARIO WITHOUT SIEM

Consider this multi-stage incident pattern:

```
1. Phishing email arrives -> 2. User opens macro -> 3. PowerShell spawns -> 4. Outbound C2 connection -> 5. Lateral movement login
```

To investigate this manually without a SIEM, you would have to log into **6 different management consoles** (Email gateway, EDR, local Windows logs, DNS servers, Firewalls, Active Directory). This approach is incredibly slow and completely inefficient.

| THE SAME SCENARIO WITH SIEM

Inside a properly configured SIEM system, the analyst experience completely transforms:

- ⚡ You execute a single unified query targeting the specific compromised user account or host asset.
- 👁️ You immediately view the chronological timeline combining email arrivals, macro events, and outbound firewall blocks simultaneously.
- 🔗 Pre-configured correlation rules automatically bundle these separate logs into a single high-fidelity incident.

| SIEM IS NOT A MAGIC TOOL

Crucial Reality Check for L1 Analysts:

A SIEM does not think for you, and it doesn't automatically detect threats out-of-the-box perfectly. Its overall capabilities are fundamentally limited by:

- 🔹 Log Quality (Is the necessary data actually being sent?)
- 🧠 Human Context (The analyst's investigative skill)
- </> Parsing rules (Is the data broken down cleanly?)
- ⚙️ Tuning accuracy (Are the alert thresholds realistic?)

"Garbage In, Garbage Out". Weak logs equal weak detection capabilities.

INDUSTRY-LEADING SIEM ECOSYSTEMS

As a Tier 1 analyst, you will likely encounter one of these industry standard platforms:

Microsoft Sentinel: Cloud-native, tightly integrated with Azure/M365 environments.

Splunk Enterprise Security: Massive data ingestion capacity, utilizes powerful SPL.

IBM QRadar: Features advanced built-in asset tracking and auto-correlation features.

Elastic Security: Highly performant open-source search framework engine.

Wazuh: Highly popular open-source host monitoring and SIEM option.

Google Chronicle: Built explicitly for massive planet-scale speed data processing.

We focus on the underlying concepts so you can easily master any tool layout.

CORE OPERATIONAL PIPELINE OF SIEM



1. Ingestion

Collecting raw logs continuously from thousands of distributed agents and API feeds.



2. Processing

Parsing raw strings, mapping structural field objects, and indexing events cleanly.



3. Analytics

Running continuous correlation lookups, alerting on threats, and rendering dashboards.

| WHAT IS A LOG SOURCE?

A **Log Source** is any system, application, appliance, or server component that generates security audit records and securely streams them directly into the SIEM storage engines.



Ingestion Methods: **Syslog Agents** | **API Integrations** | **Event Forwarders** | **File Parsers**

Every distinct log source provides a unique category of structural evidence during a live digital forensics or triage process.

ESSENTIAL LOG SOURCES FOR SOC L1

Log Source	Core Evidence Captured
Windows Security Logs	Authentications, failed logins, process creations (Event ID 4688), user management adjustments.
Linux auth.log	SSH connections, sudo privilege escalations, failed and accepted credential prompts.
Firewall / Network Logs	Allowed/blocked traffic, source/destination IPs, byte counts, protocol use.
DNS Logs	Domain name resolutions, looking for domain generation algorithms (DGA), malicious lookups.
Proxy / Web Gateway	Visited URLs, explicit file download events, web category blocks.
EDR Logs	In-depth process trees, memory injection flags, low-level endpoint alert context.
Email Gateway Logs	Inbound phishing alerts, attachment hashes, sender routing paths, authentication data.

THE LIFE CYCLE OF A LOG INSIDE SIEM

From generation to analyst screen, logs pass through these structured technical checkpoints:

Collection → Parsing → Normalization → Storage → Correlation → Alerting → Triage/Investigation

As an L1 Analyst, understanding **Parsing** and **Normalization** is critical to writing accurate search queries across different log types.

WHAT IS PARSING?

Parsing means taking unstructured raw string log text and extracting it into structured data fields.

Raw String: Mar 10 08:15:22 web01 sshd[2150]: Failed password for root from 185.20.40.9 port 51422 ssh2

```
Time: Mar 10 08:15:22
Host: web01
Service: sshd
EventStatus: Failed
```

```
User: root
SourceIP: 185.20.40.9
SourcePort: 51422
Protocol: ssh2
```

WHY IS PARSING CRITICAL?

Without proper log parsing, analysts would be forced to use slow, inefficient free-text searches across millions of raw text lines.

With accurate parsing configurations, you can execute fast, highly targeted database queries:

```
Where User == "root" and SourceIP == "185.20.40.9" and EventStatus == "Failed"
```

This structure makes threat detection rules, metric tracking, and analytical searches incredibly fast and highly accurate.

| WHAT IS NORMALIZATION?

Normalization means standardizing field names across entirely different log vendors and schemas.

Different vendors use different names to log the exact same security concept:

- Palo Alto Firewall logs: **src_ip**
- Windows Security logs: **SourceNetworkAddress**
- Cisco ASA logs: **sourceAddress**

The SIEM normalizes all of these different vendor schemas into a single uniform field name: **SourceIP**.

NORMALIZATION IN ACTION

Thanks to data normalization mapping, a single value can be tracked seamlessly across all visibility planes:

Windows Event

Logs authentication failure events
for IP **185.20.40.9**

Firewall Log

Logs connection drops or sessions
for IP **185.20.40.9**

VPN Audit

Logs remote connection attempts
from IP **185.20.40.9**

Analyst Query: `where SourceIP == "185.20.40.9"` antly.

| WHAT IS AN EVENT INSIDE SIEM?

1 Event

An **Event** is a single, isolated parsed log entry ingested into the SIEM database.

Examples: A firewall rule allow check, a single successful network connection, a DNS lookup, or a file creation log.

Crucial Rule: The vast majority of events are benign and completely normal background noise.

| WHAT IS AN ALERT INSIDE SIEM?

2

Alert

An **Alert** is generated when an incoming event—or a correlated group of events—triggers a specific, pre-defined detection rule condition.

Example Rule: Trigger an alert if a single user account accumulates more than 20 failed login events within a 5-minute window.

An alert flags an anomaly that requires human triage and analyst confirmation.

| WHAT IS AN INCIDENT INSIDE SIEM?

3 Incident

An **Incident** is a high-priority ticket that groups multiple related alerts and events into a single actionable narrative.

Example: Instead of looking at 5 separate alerts, an Incident binds the initial phishing link click, the subsequent malware alert, and the suspicious login into a single unified case file. Incidents provide full attack context for the analyst team.

EVENT VS. ALERT VS. INCIDENT HIERARCHY

Object	Context Level	Analytical Definition	Real-World Example
Event	Raw Log Trace	A single data point recording an activity.	User "Mona" failed a login.
Alert	Identified Threat	A rule match flagging a suspicious pattern.	20 consecutive failed logins for "Mona".
Incident	Full Attack Narrative	An aggregated case combining multiple alerts.	Mona's failed logins + sudden successful login + malicious forwarding rule.

WHAT IS A CORRELATION RULE?

A **Correlation Rule** is a logic block within a SIEM that analyzes completely separate data streams over time to identify complex threat patterns.

"If Event Type A occurs on Log Source X, followed by Event Type B on Log Source Y within Z minutes for the exact same asset or user metadata identity, generate a high-fidelity alert."

This allows us to identify complex attack stages that single log sources would miss.

WHY CORRELATION IS CRITICAL

Isolated events often appear benign when viewed on their own:

- ! One failed login log → Normal user typo.
- ! One firewall outbound session trace → Standard web traffic.

However, when correlated across time:

50 Failed Logins + 1 Immediate Successful Login + Outbound session to an unclassified IP

Correlation rules combine these data points to highlight the actual danger instantly.

CORRELATION LOGIC: AUTHENTICATION ATTACK

CRITERIA:

- LogSource == "ActiveDirectory_SecurityLogs"
- EventID == 4625 (Failed Login) Count > 25 within a window of 5 minutes
- Followed by EventID == 4624 (Successful Login) for the same TargetAccount
- Mapped from the same SourceIP Address

Resulting Alert Name: Brute Force Success / Credential Guessing Confirmed

Severity: High

CORRELATION LOGIC: MULTI-VECTOR MALWARE

Correlating distinct behavior patterns across different visibility zones:

Step 1: Web Proxy

Downloads an executable file (.exe) from an unclassified external domain.

Step 2: Endpoint EDR

Detects a brand new process spawning out of the User's Downloads directory.

Step 3: Firewall Logs

Identifies immediate outbound connections from that same internal host asset.

Unified Alert Name: Suspicious Staged File Ingestion and Execution

CORRELATION LOGIC: PHISHING-TO-ENDPOINT

Tying user interaction records straight into operating system telemetry:

```
Event 1: Inbound email containing a macro-enabled attachment delivered (Email Gateway Logs)  
Event 2: Local Word/Excel document process spawns a cmd.exe/powershell.exe process (EDR)  
Event 3: Outbound dynamic DNS queries resolve malicious domains (Network Connection logs)
```

⚠ Generates a unified critical risk incident file automatically.

| WHAT IS AN ALERT RULE?

An **Alert Rule** (or Analytics Rule) is the specific detection logic or search pattern configured to run continuously against data streams to generate notifications.

-  Malware Detection traces
-  Impossible Travel indicators
-  Unauthorized Admin additions
-  Audit Log Clearance events
-  Mass Port Scan actions
-  Large External Data Transfers

Alert rules must be continuously tuned. Poorly configured rule logic causes widespread Alert Fatigue.

| UNDERSTANDING ALERT FATIGUE

Alert Fatigue is a top operational risk in modern SOC's.

It occurs when analysts are overwhelmed by a continuous flood of low-fidelity alerts, repetitive notifications, and false positives.

The Danger: True malicious security alerts get lost in the noise and are missed by the team.

95%

False Positives
in untuned systems

| HOW DO WE FIX ALERT FATIGUE?

SOC engineering teams use specific tactics to manage and clean up their alert feeds:

 **Threshold Tuning:** Adjusting rules to prevent noise.

 **Deduplication:** Bundling duplicate alerts together.

Suppression Rules: Silencing known safe processes.

 **Incident Grouping:** Linking related traces into one case.

 **Severity Calibration:** Routing high-risk flags first.

| WHAT IS A DASHBOARD?

A **Dashboard** is a visual reporting interface that converts security logs into real-time metrics, charts, and trend data.

Volumetric Charts

Tracks overall ingestion patterns and firewall block rates.

Top Attacked Assets

Identifies target user accounts or hosts generating the most alerts.

Geographic Views

Maps authentication attempts from across the globe visually.

Remember: Dashboards provide operational situational awareness, but they do not replace actual case analysis.

COMMON DASHBOARD TRAPS

Do not assume a spike on a dashboard automatically means a major breach has occurred.

 Example: A dashboard showing "10,000 Inbound Firewall Blocks"

This is usually just automated internet scanning. To assess real risk, an analyst must look at the context: Was any connection successful? Did it target an exposed, unpatched asset?

ESSENTIAL FIELDS FOR SOC L1 ANALYSIS

When running a search or analysis, always focus on these normalized schema keys:

TimeGenerated: The exact UTC log ingestion timestamp.

SourceIP / DestinationIP: Network communication points.

DestinationPort: Identifies the target service (e.g., 443, 22, 3389).

Account / User: Mapped identity name.

Hostname / DeviceName: Endpoint identification tags.

ProcessName / CommandLine: Full local execution strings.

FileName / FileHash: File tracking identifiers (SHA256).

URL / Domain: Visited web properties.

EventID: Specific operating system log code indicators.

Action: Result status (e.g., Allowed, Blocked, Success).

THE INVESTIGATIVE INQUIRY MINDSET

Never search logs randomly. Always start your investigation with a clear, specific question:

Scope

"What is the exact timeframe of this anomalous behavior?"

Context

"Which specific process tree spawned this network connection?"

Blast Radius

"Has this malicious file hash appeared on any other company device?"

FORMULATING INVESTIGATIVE QUESTIONS

Incoming Security Alert: Suspicious PowerShell Execution on HR-LAPTOP-12

A trained Tier 1 analyst immediately asks:

- ❓ Who was logged into the asset at that exact time?
- ❓ What was the full command-line string passed to PowerShell?
- ❓ Did it connect to any external IP address afterward?
- ❓ Was there a related file download or phishing email right before the alert?

STEP-BY-STEP SIEM TRIAGE WORKFLOW

-  1. **Open Case:** Open the incident queue and read the alert summary carefully.
-  2. **Extract Entities:** Identify key targets (Users, Hostnames, IP Addresses, Hashes).
-  3. **Check Time Window:** Review logs from before and after the alert timestamp.
-  4. **Pivot Across Sources:** Correlate endpoint logs with network firewall logs.
-  5. **Map Timeline:** Build a chronological timeline of events.
-  6. **Render Verdict:** Determine if it is a True Positive or False Positive, then close or escalate.

THE TIME WINDOW EXPANSION RULE

Never restrict your log analysis strictly to the exact second of the alert timestamp.

Always expand your timeline window both **before** and **after** the event occurred:

Alert Time: 11:43 PM → Expand Search Window: 11:00 PM to 12:30 AM

This allows you to find critical pre-exploit activities (like phishing links or downloads) and post-exploit steps (like C2 connections or persistence mechanisms).

BUILDING A CHRONOLOGICAL TIMELINE

Your analysis must reconstruct the exact sequence of events step-by-step:

```
[11:02:10 PM] - Inbound email with delivery trace to user ahmed.  
[11:14:05 PM] - Ahmed clicks the link; Proxy logs outbound session to domain.  
[11:15:32 PM] - Excel spawns a PowerShell process running an encoded payload.  
[11:16:00 PM] - Persistent outbound beaconing connects to IP address 91.200.10.5.  
[11:25:11 PM] - Unauthorized scheduled task persistence mechanism created on host.
```

A clear timeline makes the entire incident easy to understand and respond to.

PIVOTING STRATEGY: USER-CENTRIC

A **User Pivot** means focusing your investigation on a specific user identity across all log types:

Authentication

Review Active Directory, VPN, and cloud identity access logs for suspicious activity.

Messaging

Check email gateway activity for phishing attempts or data leakage traces.

Cloud Activity

Monitor file modifications, configuration updates, and mailbox rule changes.

This strategy is highly effective for triaging Account Compromise and Insider Threat cases.

PIVOTING STRATEGY: HOST-CENTRIC

A **Host Pivot** means focusing your investigation on a specific endpoint machine asset:

-  Trace all process creations and parent/child trees.
-  Map network connections back to specific processes.
-  Audit local security logs for Event ID clearances.
-  Track new file generation and downloads.
-  Review scheduled tasks and persistence modifications.

This strategy is critical for isolating Malware infections and investigating Endpoint alerts.

PIVOTING STRATEGY: IP-CENTRIC

An **IP Pivot** means focusing your investigation on a specific network address entry:

- ↔ **Perimeter Logs:** Search Firewall and Proxy data to find every internal host connecting to that IP.
- 🌐 **Identity Feeds:** Check for remote VPN or cloud access attempts originating from that IP.
- 🌍 **Threat Intelligence:** Cross-reference the IP against known C2 infrastructures and bad actors.

Essential for assessing the scale of network scanning, brute force, and C2 activities.

PIVOTING STRATEGY: HASH-CENTRIC

A **Hash Pivot** uses a file's digital signature (like SHA256) to map its presence across the enterprise:

```
Search: where FileHash == "abc123789xyz..."
```

This allows you to answer critical containment questions instantly: Has this malicious file landed on any other endpoints? Was it blocked successfully? Who downloaded it first, and where did it originate?

PIVOTING STRATEGY: URL/DOMAIN-CENTRIC

A **URL/Domain Pivot** tracks connections to specific web properties across all systems:

-  **DNS Logs:** Identify every asset that attempted to resolve the malicious domain name.
-  **Email Gateways:** Find all incoming messages containing that specific link in the body text.
-  **Web Proxy:** Review full web paths, response codes, and data volumes transferred.

MAPPING SIEM FINDINGS TO MITRE ATT&CK

Once you extract your indicators from the SIEM, map them to the MITRE framework to understand attacker behavior:

- Local persistence scheduled task addition

SIEM Log Trace Object	MITRE Tactic Mapped
Inbound malicious delivery log entry	Initial Access
Word document spawning an encoded PowerShell process	Execution
Persistence	
Security Audit Log Clearance action (Event ID 1102)	Defense Evasion
Internal network connections using RDP or SMB shares	Lateral Movement

ANATOMY OF A HIGH-FIDELITY SIEM INCIDENT

Incident Title: Potential Phishing Attack and Account Compromise Chain

This incident is highly accurate because it links related events across completely different systems:

- Email Gateway logs: Suspicious link delivered to user Ahmed.
- Web Proxy logs: Ahmed clicked that exact link address.
- Windows Security logs: 15 failed logins followed by 1 successful login from an external IP.
- Mailbox logs: A brand new forward rule to an external address was created immediately.

VERIFYING THE ATTACK CHAIN

As an analyst, you must verify every link in the attack chain using your log sources:

1. Delivery

The Email Gateway confirms the malicious mail arrived in the inbox.

2. Access

Authentication logs confirm an unusual, successful external login occurred.

3. Persistence

Mailbox rules show the attacker is actively forwarding corporate mail data.

Verdict: True Positive. Escalate to Tier 2 immediately.

PRACTICAL EXERCISE 1: ALERT TRIAGE

Analyze this incoming SIEM alert details block:

```
Alert Name: Multiple Failed Login Attempts  
Target User Account: khaled | Mapped Source IP: 185.20.40.9 (External IP)  
Failed Attempts Count: 30 | Time Frame Window: 5 Minutes  
Subsequent Successful Login Check: No | Related Network Alerts: None
```

Evaluate: What type of log source produced this alert? What is your initial severity rating? What are your next logical search queries within the SIEM?

| ANSWER: EXERCISE 1 TRIAGING

- ✓ **Log Source Origin:** Identity Provider / Active Directory Logs.
- ✓ **Initial Severity:** **Medium** (High volume of failures, but no successful login seen yet).
- ✓ **Next Steps / Pivots:**
 1. Search the Source IP to see if it is targeting other company accounts.
 2. Monitor for any successful logins from that IP over the next hour.
 3. Verify if MFA is enabled and active for user Khaled.

PRACTICAL EXERCISE 2: CORRELATION ANALYSIS

Review these events grouped by a SIEM correlation engine:

1. Email Gateway: High-risk phishing email delivered to user Sara.
2. Endpoint Telemetry: Sara opened attachment "salary_update.xlsx".
3. Process Tree Logs: excel.exe launched powershell.exe running an encoded string.
4. DNS Queries: Host requests resolution for domain "payroll-check.example".
5. Firewall Logs: Sustained outbound connections to 91.200.10.5 on port 443.

Evaluate: Are these events isolated or part of a coordinated attack? What is the impact? What is your final verdict?

| ANSWER: EXERCISE 2 ANALYSIS

- ! **Analysis:** These events are clearly correlated. They trace a complete attack lifecycle from delivery to execution and C2 beaconing.
- ! **Incident Mapped:** Phishing attack leading to endpoint execution and active C2 communication.
- ! **Severity Level:** High / Critical.
- ! **Action:** Escalate immediately to Tier 2. The endpoint is compromised and requires isolation.

PRACTICAL EXERCISE 3: CREATING SEARCH QUERIES

You receive an isolated network threat flag from the firewall:

Network Alert Trace: Suspicious outbound connection from host HR-LAPTOP-12 to external IP 45.77.20.10 on port 443.
Traffic occurs consistently every 60 seconds.

Task: Write 6 specific investigative questions to run inside the SIEM to uncover the root cause of this connection.

| ANSWER: EXERCISE 3 INVESTIGATIVE STRATEGY

- Q 1. Which local process ID and process name initiated the network session?
- Q 2. What was the exact parent process that spawned that calling application?
- Q 3. Did a DNS lookup for a domain name happen immediately before the connection?
- Q 4. Have any other hosts in the company connected to that same external IP?
- Q 5. Does this IP address trigger any hits in our threat intelligence feeds?
- Q 6. Were any new scheduled tasks or startup files created on that laptop recently?

COMPREHENSIVE PRACTICAL SCENARIO

A high-priority incident is opened in the SIEM queue:

Incident: Possible Account Compromise and Malicious Endpoint Activity

The case file bundles 10 distinct event traces involving user account **ahmed** and host asset **HR-LAPTOP-14** over a 30-minute period. Your task is to analyze these logs, identify the source systems, map the timeline, and determine the correct response action.

SCENARIO ANALYSIS: MAPPING LOG SOURCES

Observed Trace Element	Required Log Source Provider
18 Failed login attempts from external IP 185.20.40.9	Active Directory / Cloud Identity Logs
Sudden successful login from that same external IP	Active Directory / Cloud Identity Logs
Login from a new country flag ("Impossible Travel")	Identity Provider Geo-IP Analytics
Inbound delivery trace for email titled "Salary Update"	Email Gateway Logs
User clicked link within the email body text	Web Proxy / Secure Web Gateway Logs
excel.exe spawned a powershell.exe execution call	EDR / Host Process Audit Logs
Persistent beaconing connection to 91.200.10.5:443	Network Firewall / Proxy Sessions

SCENARIO ANALYSIS: RECONSTRUCTING THE TIMELINE

1. [02:00 PM] - Phishing email titled "Salary Update" delivered to user Ahmed.
2. [02:05 PM] - Ahmed clicks the link; Proxy logs outbound session to the domain.
3. [02:06 PM] - 18 failed logins from external IP 185.20.40.9 targeted Ahmed's account.
4. [02:11 PM] - A successful login from 185.20.40.9 occurs, triggering an Impossible Travel flag.
5. [02:12 PM] - Ahmed opens the attachment; excel.exe launches encoded PowerShell.
6. [02:13 PM] - Local DNS resolves salary-check-update.example domain address.
7. [02:14 PM] - Persistent outbound connections to 91.200.10.5 occur every 60 seconds.
8. [02:18 PM] - An unauthorized mailbox rule is created to forward all mail to an external address.

SCENARIO ANALYSIS: MITRE ATT&CK MAPPING

Incident Lifecycle Element	MITRE ATT&CK Tactic Mapped
Phishing delivery vector ("Salary Update")	Initial Access (T1513)
Ahmed clicking the link and running the attachment	User Execution (T1204)
18 failed login attempts followed by success	Credential Access / Brute Force (T1110)
Successful external login from a new country	Initial Access / Valid Accounts (T1078)
Excel launching an encoded PowerShell string	Execution / PowerShell (T1059.001)
Sustained connection cycles to 91.200.10.5:443	Command and Control / Web Protocols (T1071.001)
Mailbox rule created to forward all mail data	Persistence / Collection (T1114)

SCENARIO ANALYSIS: FINAL VERDICT

Severity Assessment: **Critical**

Confidence Rating: **High**

Final Decision: **Escalate Immediately**

Justification Statement

This is a confirmed multi-stage attack. We have clear evidence of a successful phishing exploit, endpoint compromise via PowerShell, credential theft, and active data exfiltration via mailbox forwarding. This requires immediate incident response containment.

WRITING THE PROFESSIONAL CASE SUMMARY

Your escalation report to the Tier 2/IR team must be clear, concise, and professional:

"The SIEM incident shows multiple related events involving user ahmed. A salary-themed email was delivered and the user clicked the link. Shortly after, 18 failed login attempts from an external IP were followed by a successful login and a login from a new country. Endpoint telemetry shows Excel launching encoded PowerShell, followed by DNS activity to a suspicious domain and repeated outbound connections to 91.200.10.5:443. A mailbox forwarding rule was also created. The activity indicates possible credential compromise, suspicious execution, and possible C2 communication. Escalation to Tier 2 is required."

TOP MISTAKES TO AVOID IN SIEM ANALYSIS

- ✗ **Alert Name Reliance:** Trusting the alert title without inspecting the raw events.
- ✗ **Ignoring Time Context:** Failing to expand the search window before and after the alert.
- ✗ **Siloed Analysis:** Checking only one log source and ignoring related data streams.
- ✗ **Random Searching:** Querying logs blindly without a clear investigative question.
- ✗ **Dashboard Reliance:** Treating high-level dashboard charts as a substitute for real triage.

THE ANALYST'S GOLDEN RULE



"A SIEM provides you with logs, alerts, incidents, and charts. But only the human analyst can connect them to build a timeline, understand the context, evaluate severity, and make the final decision."

The tool is only as good as the analyst operating it.

LECTURE SUMMARY

- SIEM unifies scattered infrastructure logs into one brain interface.
- Parsing structures raw strings; Normalization standardizes field names.
- Events are data points, Alerts are flags, Incidents are attack stories.
- Correlation rules connect data points across time to find threat patterns.
- Effective triage requires pivoting across User, Host, IP, and Hash entities.
- Your investigations must always generate a clear timeline and professional summary.

REVIEW QUESTIONS

1. What does the SIEM acronym stand for?
 2. Why do modern SOC teams rely on a centralized SIEM platform?
 3. What is the technical difference between data Parsing and Normalization?
 4. Differentiate clearly between a SIEM Event, Alert, and Incident.
 5. How does a correlation rule distinguish an attack from normal background noise?
 6. What is Alert Fatigue, and how do engineering teams reduce it?
1. Why must an analyst expand their time search window during triage?
 2. Explain the concept of User Pivoting versus Host Pivoting.
 3. What critical evidence do DNS logs provide during a phishing case?
 4. Why can an email with an "SPF Pass" verification still be highly dangerous?
 5. What is the risk of an unauthorized mailbox forwarding rule?

KNOWLEDGE ASSESSMENT QUIZ

1. What does a data Normalization rule do?

A) Deletes raw logs | B) **Standardizes distinct field names into a uniform schema** | C) Resets user passwords | D) Blocks network ports.

2. A correlation rule is explicitly built to:

A) **Link events from separate sources to uncover threat patterns** | B) Compress database files | C) Clear firewall rule logs | D) Render graphics.

3. If an incoming email returns a successful "DMARC Pass", it guarantees the content is safe.

A) True | B) **False (The attacker may have configured authentication correctly on a lookalike domain).**

4. Investigating all actions associated with a specific machine name across your logs is called a:

A) User Pivot | B) **Host Pivot** | C) Hash Pivot | D) IP Pivot.

LECTURE HOMEWORK ASSIGNMENT

Triage and document this complex SIEM incident file using the standard analysis template:

- Incident Target: User "mona" | Host Asset: "FIN-WORKSTATION-09"
- Inbound email from external provider containing an urgent MFA link delivered to Mona.
- Web logs show Mona clicked the URL path: `hxxps://company-mfa-verify.example/mfa`
- 12 Failed login entries are followed by a successful authentication from IP 185.20.40.9.
- An Impossible Travel alert flags a concurrent cloud connection from a new foreign country.
- `winword.exe` launches a `powershell.exe` call passing an encoded payload argument string.
- Local host executes a DNS Query string resolving host address: `mfa-update-check.example`.
- Host opens persistent network sessions to IP 45.77.20.10 on port 443 every 60 seconds.
- A new mailbox synchronization rule is created to forward all incoming corporate mail messages out.

Deliverables: Map required log sources, reconstruct the timeline, map MITRE tactics, list 8 pivot questions, write an initial analysis summary, and state your final escalation decision.

SIEM INCIDENT TRIAGE TEMPLATE

Incident Title Name:

Affected Targeted Identities (User/Host):

Triage Time Window Scope:

Identified Involved Log Sources:

Chronological Timeline Layout:

Pivots Executed during Analysis:

MITRE ATT&CK Framework Mapping:

Calculated Severity Rating Assessment:

Analysis Confidence Level:

Final Case Action Decision (Close/Escalate):

Recommended Containment Actions:

Professional Initial Analysis Narrative:

| HOMEWORK EVALUATION ANSWER KEY

Core Threat Profile: Phishing attack leading to credential theft, endpoint exploitation via Word macros, and data exfiltration persistent rules.

Severity Mapped: Critical | **Decision:** Escalate immediately to Tier 2 / IR.

Summary: The SIEM incident shows a suspicious MFA-themed phishing email delivered to user mona, followed by a click to a suspicious URL. Authentication logs show 12 failed logins followed by a successful login from the same external IP and a login from a new country. Endpoint logs show Word launching encoded PowerShell, followed by DNS activity to a suspicious domain and repeated outbound connections to 45.77.20.10:443. A mailbox forwarding rule was created to an external address. This activity suggests possible credential compromise, suspicious execution, and possible C2 communication. Escalation to Tier 2 is required.

NEXT LECTURE SNEAK PEEK...



Lecture 10: KQL Querying for Beginners

Mastering the Kusto Query Language framework to hunt threats inside modern SIEM systems.

Operators covered: where | take | contains | summarize | count | ago